Detection of Payload-Free Pretexting Emails Through Claim-Routed Verification Against Email Headers and Thread History

[Author 1 name]*
[Department]
[Organisation]
[City, Country]
[email address]

[Author 2 name]
[Department]
[Organisation]
[City, Country]
[email address]

***Abstract*—Pretexting emails often carry no link and no attachment, and a sender who writes from a free mailbox or a lookalike domain passes SPF, DKIM and DMARC for that domain. This paper describes a claim-routed verification pipeline that extracts typed claims from the body and routes each one to the header or thread rules that can test it. Every verdict is a ledger row naming the claim, the rule and the evidence, so each of the 442 test emails the pipeline flagged has a stated reason. On synthetic takeover replies injected into real threads, the thread rules detect 18 of 25 Apache and 48 of 51 Enron cases, against 5 and 0 for the header and request rules alone. A payload-free protocol, run on corpus labels with one training sample and two seeds, shows that a detector trained on raw text owes part of its accuracy to reading links: under link redaction its F1 drops by 0.073 more than that of a model trained on redacted text, with a bootstrap interval from 0.061 to 0.086. The pipeline is not the best pooled detector. On 3,045 test attacks and 6,357 legitimate emails its F1 is 0.238, against 0.882 for parallel fusion of text and header classifiers, and its AUC is the lowest of five systems.**

Keywords—business email compromise, pretexting, phishing detection, email authentication, claim verification, thread hijacking

I. Introduction

Business email compromise (BEC) is pretexting aimed at money: the attacker poses as a trusted person, such as an executive or a supplier, and asks for a payment, a change of bank details or data. In 2025 the Internet Crime Complaint Center of the FBI recorded 24,768 BEC complaints and $3,046,598,558 in reported losses [1]. The 2026 Data Breach Investigations Report defines pretexting as building a trusted relationship through invented scenarios, by voice, email or text, with the attacker taking part in the conversation or email thread, and finds it to be the initial access vector in 6% of breaches [2].

These emails may be empty of any attachments or links and thus be unable to be scanned, which is the reason. Imagine that there is a message from Finance signed by David that requests an accounts clerk at acmecorp.com to wire funds before 3 PM, and not to let anyone know.Suppose there is a message signed by David from Finance, requesting an accounts clerk at acmecorp.com to wire funds before 3 PM and not to tell anyone. It is from a real gmail.com account, so it passes SPF [3], DKIM [4] and DMARC [5] as gmail.com, but not as other account types. Authentication serves to identify the domain from which a message has originated, but is not an indicator of who or what the body actually is. It is only apparent as a disagreement between what the body says and what the headers provide.

Detectors that could see this disagreement mostly look elsewhere. Work on phishing from compromised accounts focuses on emails with a malicious URL, and its authors note that their data likely underestimate attacks without one [6]. BEC-Guard judges impersonation from an organisation's header history and classifies the body only after removing names and signatures [7], so the statements that say who is writing are never compared with the headers. ChatSpamDetector asks GPT-4 to look for brand impersonation and header spoofing, which covers part of this comparison, but its data exclude emails without a URL and each email costs one model call [8].

We treat the problem as fact-checking. Automated fact-checking divides the task into claim detection, evidence retrieval and claim verification, which gives a verdict and its justification [9]. Here the claims are what an email says about itself and the evidence is its own headers and, for a reply, the earlier messages of its thread. A claim to be a colleague is checked against the authenticated domain, a payment request against who is asking, and a reply against the history it joins. An account that has been taken over passes every header check, so against that attacker the thread is the only evidence left.

The major contributions of paper are: 1) The claim-routed verification pipeline, in which typed claims are routed to the header, request or thread rules that can test them and every finding is a ledger row naming the claim, the rule and the evidence. 2) A payload-free evaluation protocol, N1, which redacts links, addresses, domains and file names and measures how much of a detector's accuracy comes from reading links. 3) Thread consistency verification, N2, which compares a reply with its own thread. 4) An evaluation with frozen components, a test log, grouped bootstrap intervals and results per source, which also shows that the pipeline is not the best pooled detector on public corpora.

II. Related Work

Persuasion and tactics. Persuasion is measurable in email text. Karki et al. tag persuasion principles in phishing emails with transformer classifiers and report an average F1 of 0.9 for RoBERTa on five principles, with labels produced automatically by sentence similarity to manually written examples [10]. Tooher and Lallie detect phishing from persuasion principles in two stages and report 94% accuracy, but their phishing emails were generated by a language model and labelled by design while their legitimate emails are real [11]; in such a set, writing style alone can separate the classes. Across seven public corpora, Pan et al. find every persuasion principle more often in phishing than in legitimate mail, yet authority cues still appear in 27.10% of legitimate samples, and the authors note that targeted attacks such as BEC may not be represented in such corpora [12]. These studies read the body only. In the pipeline a tactic is a modifier: it raises the weight of a contradiction and never creates one.

*Corresponding author.

Identity from metadata and history. BEC-Guard first decides from an organisation's header history whether a sender impersonates an employee and only then classifies the body and its links, after removing names and signatures from the text; it reports a precision of 98.2% on more than 4,000 attacks, and account takeover is outside its focus [7]. Gascon et al. profile senders from the structure and transport traits of their emails without reading the text, detecting 90% of spoofed emails at fewer than one false alarm in 10,000; they note that such infrastructure features model the sender's environment rather than the author, so a hacked account cannot be detected with them [13]. These systems ask whether an email fits its sender's history. The pipeline asks whether what the email claims matches its own headers, needs no mail history beyond the thread being checked, and looks for account takeover in the thread itself. We did not find an academic detector of thread hijacking with an open evaluation.

Claims and model judgement. Paul et al. label 940 emails with the warning signs that users are taught to look for, including the organisation a sender claims to be from and train a different classifier for each sign, finding that the mismatch between such a claim and the metadata is often as good a sign as the content of the email, and assume that such a mismatch is verified in a downstream algorithm. The pipeline is such an algorithm. This paper is not the first to compare a claimed sender to the headers, since ChatSpamDetector reports 99.70% accuracy on 2010 emails, using a GPT-4 prompt that contains a check for a mismatch between a claimed sender name and address [8]. Detection over entire conversations has been examined for chat, where ConvoSentinel is able to identify social engineering attempts at the message and conversation level, but does not have the header and thread data metadata that email does [15]. The pipeline has no call to a model at runtime, and is evaluated on redacted text and on emails that don't contain a link, whereas checking typed claims with fixed rules saves the reason, when evaluated.

III. Problem and Threat Model

An email is payload free if it doesn't contain a link, or an attachment, and the attack is limited to what the email says to do. Defender is receiving organisation. One email or a thread are inputted, the organisation's own domain if known, otherwise not checkable are recorded as such, not guessed..

Outside impersonator. The attacker's email is sent from a free mailbox, a domain name that closely resembles the organization's name, or their own domain, that is spoofed, with a display name and a Reply-To selected to mislead. The following examples illustrate this: A sender from a free mailbox or a domain similar enough to the mailbox passes SPF, DKIM and DMARC on its own domain name; A sender from a spoofed domain name fails DMARC if the organization publishes a domain name policy. The association of the body and the headers is not what the header rules (N3) are looking for.

Attacker inside a real account. Once an account is compromised, or a vendor is compromised, or a hijacked thread, the mail appears as if it has come from the real sender's domain, and passes authentication, so the header rules don't have anything to fight against. The talk is different, a new sense of urgency, a new bank account, a new route for the money to be sent. The thread rules (N2) search for that and they also test a new email that quotes a conversation that never occurred.

Trust in headers. All headers are sent only by the sender, with the exception of added by the receiver. Only Authentication-Results fields with an extension from the receiving organisation are trusted, per RFC 8601: (16) If there is no extension added, it is not a pass, it will be considered unknown. That is an out of scope attacker who reads the mailbox and copies the reply identifiers, the sending information and the calm tone of the real sender; no security rule will catch this attacker.

IV. The Claim-Routed Verification Pipeline

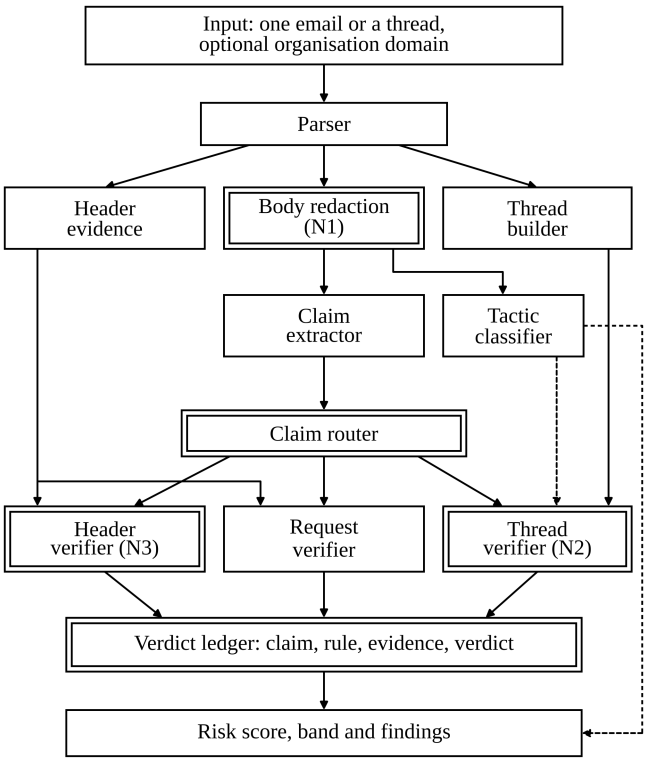


Fig. 1. The claim-routed verification pipeline. Double borders mark the parts introduced here; the dashed line carries tactic probabilities to the thread verifier (tactic onset) and to the score (urgency and secrecy as modifiers).

Fig. 1 shows the pipeline. A parser splits each message into headers, body and thread links, and three branches follow: header evidence, body redaction and, for a thread, a thread builder that orders the messages and keeps each one's quoted history.

A. Redaction, Claims and Tactics

Any model/rule that reads the body before it is cleaned is masked by placeholders such as [URL], [EMAIL], [DOMAIN] and [FILE] for email addresses, URLs, actual domain names and file names of attachments, respectively; words like see attached are not redacted. The claim extractor is constructed of a tokenizer, a name recogniser and 85 token patterns; nothing in it is trained when the redacted text and its signature block are read. It sends out typed claims including an affiliation, authority, reply direction and signature contact (both internal and external); a prior relationship; and 5 claim types (payment, payment change, credential, gift card, data). In addition to the extractor, a tactic classifier outputs probabilities of seven tactics, which include authority, scarcity, reciprocity, social proof and liking (from the persuasion literature [17]), urgency (from the time principle [18] and isolation or secrecy.

B. Routing and Verification

The router sends affiliation, authority, reply direction and signature claims to the header verifier, a claim of a prior relationship to the thread verifier, and each request to the request verifier and, when a thread is present, also to the thread verifier. Tactics go to no verifier, because no header can prove or disprove urgency.

The header verifier (N3) compares three domains: the From domain the reader sees, the domain that authentication vouched for and the domain the claim implies, which is the organisation's own domain or a known brand's domains. A contradiction is a mismatch that the claim makes meaningful, so the same header values mean different things under different claims: dmarc=pass for gmail.com is normal for a private Gmail user and a contradiction of high severity under *this is David from Finance*. The request verifier asks who is asking: a free mailbox outside the organisation, a lookalike sender, a failed DMARC check or a Reply-To to another domain. A change of bank details can never be confirmed by headers and is left to the thread.

The thread verifier (N2) judges each message against the messages before it on four signals: tactic onset, where a tactic crosses its threshold for the first time and well above its earlier average; request drift, such as new bank details or a first credential request; sending path drift, such as the same address from a new network and mail program or the sender's name at a lookalike domain; and thread integrity, where reply identifiers point to no earlier message or quoted text never appeared in the thread. The first message with a medium or high contradiction is reported as the point where the thread flipped.

C. Verdict Ledger and Risk Score

Each verifier registers a ledger line with one of 3 verdicts: contradiction with high, medium, or low severity; consistent; or there is no evidence for which to register a verdict of not checkable. Each row is labeled with a claim, a rule, some evidence and a reason using fixed templates. Only contradictions are used in the risk score. Each row of a claim has a value: High row – 60 points, Medium row – 35 points, Low row – 5 points – the highest row of a claim is valued, with each subsequent row having a value that is half of the previous row. The three rules that the fire is likely to fire on legitimate mail are all zero. Urgency + secrecy = 0.25 each = 0.50, four main tactics = +4 each = +4, at most 12, which cannot get the Suspicious band to 35 = 70. These weights were set on the validation data prior to reading the test data. The section starts with an example to show how Section I is applied in Table I..

TABLE I. LEDGER FOR THE EXAMPLE OF SECTION I

Claim and span	Verifier	Evidence	Row
affiliation_internal "this is David from Finance"	header	From gmail.com, a free mailbox; authenticated as gmail.com; organisation acmecorp.com	contradiction, high hv_int_freemail 60 points
payment_request "process a wire"	request	payment request from a free mailbox outside acmecorp.com	contradiction, high rv_freemail +30 points

Score 90, High risk, before any tactic points. The Reply-To to protonmail.com appears in the findings but adds no row, because the body makes no claim about where replies should go.

The pipeline is written in Python. The tactic classifier is a pre-trained DistilBERT model [19] that has been fine-tuned on the real and synthetic train emails in Section V, while the thresholds are tuned on the validation set. There is no language model running when analyzing and the analyzed email is only kept in memory for the request.

V. EVALUATION DESIGN

The evaluation includes the following points that Arp et al. [20] have identified: the test split is frozen prior to reading, results are reported by source, and a separate test is used to measure the difference in the collections with respect to wording only.

A. Data and Labels

The 99,324 unique emails come from 9 public sources: legitimate mail and spam from the CEAS-08 and the Enron corpora [23,26] (with authentication headers); phishing attacks from the Nazario corpus [21] and from the honeypot collections [22] and two Apache user lists [26] (with authentication headers). Split by source, category and also, emails with one subject are grouped: 69,542 train emails, 14,879 validation emails and 14,903 test emails. These are not two separate sources and a pooled score combines corpus and detection, and results are also reported per source.

The posts were reconstructed into real threads by subject, by date and by participants, using the raw Enron corpus, and by reply identifiers, using the Apache lists, which resulted in 1,591 threads. In both test cases, a synthetic message is stuffed in place of the next real one in one of the three cases: A) a lookalike domain swap where the text is benign and the sender, server, mail program identifiers are copied from the real sender; B) a lookalike domain swap with benign text and a new sending path (Apache only, since raw Enron stores no headers that contain the sending path); C) a forged thread with a fabricated quotation and, in Apache, unknown reply identifiers. The negatives are the real next reply and a synthetic benign continuation. Language models of one family were used to write the injected texts.

For the tactics and claims, 700 real emails were drawn, a fixed number per source and category. Two language model annotators from one model family labelled seven tactics and eleven claim types, and a third model of the same family broke ties; 690 emails were labelled, 140 of them in the test split. Mean Cohen's kappa between the two annotators was 0.501 over the tactics and 0.458 over the claim types. No human labels were collected, although LLM labels need validation against human labels task by task [27], so every tactic or claim score is agreement with one model family. 222 synthetic pairs, each an attack and a benign twin, cover rare tactics and are reported apart.

B. Experiments

Payload-free protocol (N1). Two DistilBERT models separate attacks (phishing, fraud) from other mail (ham, spam): model A is trained on raw bodies and model B on redacted bodies, from one training sample of 9,856 emails with two seeds and a fixed threshold of 0.5. A TF-IDF and logistic regression pair, fitted on the same sample and on all train emails, is a second family. Each model is tested on the raw and redacted views of the test split and on the test emails that never had a link. The quantity of interest is A's drop in F1 on the attack class from raw to redacted, minus B's drop: a model that reads links as a shortcut [28] loses more when they are removed. The labels are corpus labels.

Thread consistency (N2). The thread verifier is compared with the header and request verifiers alone on the test cases; a case is detected when the injected message receives a medium or high contradiction.

Claim conditioning (N3) and architecture. The frozen routed score, flagging at Suspicious or above, is compared with four logistic regressions fitted on the train split, attack against ham: text only (tactic probabilities and claim counts), headers only (authentication verdicts, free mailbox, lookalike, Reply-To and similar fields), parallel fusion (the mean of the text and headers scores) and a flat classifier given every ledger signal as one vector without the link between a claim and its evidence. Each learned system is held to the false alarm rate the frozen score shows on validation ham, 0.14%, with a floor of 0.5%. A synthetic arm adds 31 pairs in which a colleague is impersonated, with header blocks written by rule: the attack comes from a free mailbox or a lookalike domain that passes its own authentication, and its twin from the organisation's own domain.

C. Protocol

Before the first test run a freeze record stored a SHA-256 hash of every frozen file (the patterns, the rules, the score weights, the model weights and the thresholds), and every script refused to read the test split if one differed. Every script was rehearsed on the validation split before it read the test split, and every test run is logged. Intervals are 95% percentile intervals from 1,000 bootstrap resamples that draw whole groups (subject groups for emails, threads for hijack cases, pairs for synthetic emails), and differences between systems are paired. Cells with fewer than 10 positives are reported as counts.

VI. Results

TABLE II. MAIN RESULTS ON THE TEST SPLIT

(a) Pooled detection: 3,045 attacks against 6,357 ham

System	F1 [95% interval]	Recall	FAR	AUC
Routed score	0.238 [0.204, 0.277]	13.6%	0.3%	0.812
Text only	0.639 [0.612, 0.666]	47.4%	0.5%	0.949
Headers only	0.788 [0.767, 0.810]	65.5%	0.3%	0.966
Parallel fusion	0.882 [0.869, 0.895]	80.3%	0.8%	0.993
Flat classifier	0.658 [0.629, 0.687]	49.7%	0.5%	0.949

(b) Synthetic messages in real threads: cases flagged

Case	Source	Cases	Thread rules	Header and request rules
A, takeover	Apache	25	18	5
A, takeover	Enron	51	48	0
B, lookalike swap	Apache	17	17	0
C, forged thread	Apache	25	25	0
C, forged thread	Enron	51	45	0
Real next reply	Apache	25	0	0
Real next reply	Enron	51	1	0

(c) Links: DistilBERT F1 on the attack class; corpus labels; 9,856 training emails, two seeds

Model	Raw	Redacted	Raw minus redacted
A, trained on raw	0.935	0.877	+0.059 [+0.050, +0.069]
B, trained on redacted	0.918	0.932	−0.014 [−0.019, −0.009]
A's drop minus B's drop			+0.073 [+0.061, +0.086]
Same, TF-IDF, sample			+0.035 [+0.025, +0.046]
Same, TF-IDF, all train			+0.028 [+0.021, +0.037]

FAR: false alarm rate on ham. Learned systems are held to the routed score's validation false alarm rate with a 0.5% floor. Intervals: 1,000 resamples of whole subject groups or threads.

A. Pooled Detection

Table II(a) compares the routed score with four learned systems that use the same information. On 3,045 test attacks against 6,357 test ham it detects fewer attacks than any of them: its F1 is 0.238 [0.204, 0.277] and its recall 13.6%, against an F1 of 0.639 for text only, 0.788 for headers only, 0.882 for parallel fusion and 0.658 for the flat classifier. All four paired differences in F1 lie below 0; routed minus fusion is −0.644 [−0.678, −0.605]. The AUC, which needs no cut, is also the lowest (0.812 against 0.949 to 0.993). Three things limit this comparison and none removes the gap: the learned systems were fitted on attack labels and the routed score uses none, a model of the headers alone can partly learn which corpus an email came from, and the 0.5% floor lets each learned system flag more validation ham than the routed score does. Table III gives the rates per source. The attack sources differ in their header evidence: headers only detects 99.5% of the phishing_pot attacks but 2.5% of the Nigerian fraud emails, whose original headers were not kept, while the routed score detects 7.4%, 15.3% and 22.8% of the phishing_pot, Nazario and Nigerian fraud attacks. On the ham of every source all five systems flag at most 3.1%; spam, which no system was fitted on, is flagged at up to 25.5% (SpamAssassin, headers only) and at most 4.0% by the routed score.

TABLE III. SHARE FLAGGED PER SOURCE ON THE TEST SPLIT

Source	Emails	Routed	Text	Headers	Fusion	Flat
Nigerian fraud	486	22.8%	46.1%	2.5%	74.3%	52.9%
Nazario	1,439	15.3%	58.9%	60.4%	83.9%	58.3%
phishing_pot	1,120	7.4%	33.2%	99.5%	78.3%	37.1%
Apache Kafka (ham)	158	1.3%	0.0%	0.0%	0.0%	0.0%
Apache Tomcat (ham)	324	0.0%	0.0%	0.0%	0.0%	0.0%
CEAS-08 (ham)	2,588	0.6%	0.4%	0.0%	1.6%	0.3%
Enron (ham)	2,313	0.0%	0.8%	0.0%	0.0%	1.0%
Ling (ham)	359	0.0%	0.3%	0.0%	0.0%	0.3%
SpamAssassin (ham)	615	0.0%	0.3%	3.1%	1.5%	0.5%
CEAS-08 (spam)	3,126	0.0%	2.1%	0.1%	10.2%	2.0%
Enron (spam)	2,055	0.0%	8.6%	0.0%	0.0%	8.0%
Ling (spam)	69	0.0%	7.2%	0.0%	0.0%	7.2%
SpamAssassin (spam)	251	4.0%	12.3%	25.5%	24.7%	15.5%

First three rows: attacks detected. Ham rows: false alarms. Spam rows: share flagged; no system was fitted on spam. The learned systems are held to the routed score's validation false alarm rate with a 0.5% floor.

Because only contradictions can lift an email to Suspicious, the routed score can flag only emails with a checked claim, and 788 of the 3,045 test attacks have one (398 of the 6,357 ham). On these emails its F1 is 0.679 [0.633, 0.734]. It is not distinguishable from text only (difference −0.063 [−0.136, +0.026]) or headers only (−0.057 [−0.119, +0.003]), remains behind parallel fusion (−0.260 [−0.305, −0.211]) and the flat classifier (−0.174 [−0.214, −0.135]), and has a higher false alarm rate on that ham than text only or headers only (4.3% against 1.5% and 0.5%).

Every email the routed score flagged has a claim, a rule and evidence behind it (442 of 442); none of the flat classifier's 1,819 flags names a claim. This is a property of the design, not a measured gain. On the 31 synthetic impersonation pairs the routed score flagged 19 attacks (61.3% [45.2%, 77.4%]) and 0 twins. Headers only flagged all 31 attacks and all 31 twins, parallel fusion 17 attacks and 4 twins, the flat classifier 17 and 0, and text only 11 and 0. The text and the headers of this arm are synthetic.

B. Thread Consistency

On variant A, which changes only the content, the thread rules detect 18 of 25 Apache cases (72.0% [52.0%, 88.0%]) and 48 of 51 Enron cases (94.1% [88.2%, 100.0%]), against 5 of 25 and 0 of 51 for the header and request rules alone (Table II(b)). Variants B and C each change one thing the rules are

defined to check, so detecting them mainly confirms that the rules work as specified. When the whole thread is scanned, the first contradiction falls on the injected message in 17 of 25 Apache and 40 of 51 Enron takeover cases. The thread rules flagged 0 of 25 real next replies on Apache and 1 of 51 on Enron. On all real, unmodified test threads they raised a medium or high contradiction on 4.44% [3.08%, 5.99%] of 698 Enron messages with earlier messages, 0.50% of 201 Tomcat messages and 0.00% of 95 Kafka messages. The injected messages and their headers are synthetic, so these rates test the rules against the construction rather than against real attackers.

C. Payload-Free Protocol

With corpus labels and one training sample of 9,856 emails and two seeds, model A loses F1 on the attack class when links are redacted at test time (raw minus redacted +0.059 [+0.050, +0.069]); model B does not (−0.014 [−0.019, −0.009]). A's drop minus B's drop is above 0 in all three families (Table II(c)), so a detector trained on raw text owes part of its accuracy to reading links. The loss sits in the phishing sources. A's recall falls from 94.5% to 75.7% on phishing_pot and from 94.1% to 86.0% on Nazario when links are redacted, and stays at 99.4% on Nigerian fraud, while B reaches 94.3% and 93.9% on the redacted phishing_pot and Nazario attacks. B on redacted text scores 0.932, against 0.935 for A on raw text, so training on redacted bodies keeps most of the accuracy. On the 696 test attacks that never had a link the two DistilBERT models are not distinguishable (0.863 [0.840, 0.884] and 0.862 [0.839, 0.884]), but that subset is a different mix of sources, so its F1 does not compare the same emails before and after redaction. A rule that flags every email with a link reaches an F1 of 0.413, with a false positive rate of 46.5% on ham.

D. Tactics, Claims and Score Budget

On the 140 labelled test emails, whose labels come from one model family, the tactic classifier's macro F1 over authority, urgency, scarcity and secrecy is 0.479 [0.370, 0.574], against 0.500 [0.408, 0.581] for a keyword baseline with thresholds tuned on validation; the paired difference, −0.021 [−0.144, +0.091], includes 0, so neither is better. Per tactic the point estimates favour DistilBERT for authority (0.526 against 0.167, 25 positives) and the baseline for scarcity (0.436 against 0.632, 26) and secrecy (0.381 against 0.645, 16), and are close for urgency (0.574 against 0.557, 44). The claim extractor's macro F1 over the five claim types with at least 10 positives in both validation and test is 0.568 [0.470, 0.646]. Its strongest type is authority (0.718 [0.526, 0.870]) and its weakest internal affiliation (F1 0.250 [0.000, 0.533], 2 of 12 found), on which the two annotators agree with each other at an F1 of only 0.410. The frozen score stayed within its false alarm budget (High risk for at most 1% and Suspicious or above for at most 5% of checked legitimate mail per source) in 4 of 5 groups with at least 20 checked emails. CEAS-08 ham was over, at 5.60% of 268 checked emails, with an interval [3.42%, 9.03%] that still includes the budget.

VII. Discussion and Limitations

The results support the payload-free protocol, the thread checks and the traceability of alarms, within the limits below. They do not support the expectation that checking claims against their evidence detects more attacks than simpler uses of the same information. On these corpora it detects fewer.

Tactic and claim scores are agreement scores with LLM labels from one family of model, N1 labels are corpus labels. No source contains both attacks and regular mail, so all pooled numbers combine corpus and detection. The collections also vary in terms of their wording only. Because real and synthetic attack emails can be separated by their words with AUC= 1.000 [1.000, 1.000] (90 real and 31 synthetic test emails), they are reported separately and even two sources of the same kind are separated by their words with a median AUC of 0.996 over 24 such pairs. Both the learned comparators observed attack labels and a model of the headers can partially learn to what corpus an email is coming from. Both favour the learned systems. The hijack cases and the synthetic header blocks and paraphrases were produced by a language model or by rule, indicating that the rules do what they are supposed to do, not the rate that which real attackers do it. N1 is based on 1 training sample and 2 seeds, meaning that its intervals encompass the test sample and are not the training randomness. They started with 24 flags, but 18 of them were retained by rewording with a language model, and 6 new ones were added among 120 that were not flagged before; the headers were not changed, so a header contradiction is inherently present; meaning was tested on six pairs, but not on the others. The only drawback is that the checks of internal affiliation require the organisation, and many public corpora don't disclose it, and the extractor reads only English. No rule is triggered by the copying of the identifiers, the sending details and the tone of a real thread by an attacker.

VIII. Conclusion

The check of the claimed content against the header and the thread provides a clear justification for every alarm and uncovers synthetic takeover replies in real threads that are not detected by the header and request rules. However, on the pooled detection on public corpora, the routed score is not as good as any of the four learned classifiers; therefore, there is no such thing as more attacks being detected on the public corpora due to the design itself. The cost of redaction of links is minimal and it strips a shortcut. The work should be done on some real attacks with labelled payload-free BEC and with real hijacked threads which preserve the authentication headers of the receiving side; a sample of emails should be labelled by people for tactics and claims.

References

[1] Federal Bureau of Investigation, Internet Crime Complaint Center, "2025 IC3 annual report." Accessed: Oct. 12, 2026. [Online]. Available: https://www.ic3.gov/AnnualReport/Reports/2025_IC3Report.pdf

[2] Verizon, "2026 data breach investigations report," 2026. Accessed: Oct. 12, 2026. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

[3] S. Kitterman, "Sender Policy Framework (SPF) for authorizing use of domains in email, version 1," RFC 7208, Apr. 2014, doi: 10.17487/RFC7208.

[4] D. Crocker, T. Hansen, and M. Kucherawy, Eds., "DomainKeys Identified Mail (DKIM) signatures," RFC 6376, Sep. 2011, doi: 10.17487/RFC6376.

[5] T. Herr and J. Levine, Eds., "Domain-based message authentication, reporting, and conformance (DMARC)," RFC 9989, May 2026, doi: 10.17487/RFC9989.

[6] G. Ho et al., "Detecting and characterizing lateral phishing at scale," in *Proc. 28th USENIX Security Symp.*, Santa Clara, CA, USA, 2019, pp. 1273–1290.

[7] A. Cidon, L. Gavish, I. Bleier, N. Korshun, M. Schweighauser, and A. Tsitkin, "High precision detection of business email compromise," in

Proc. 28th USENIX Security Symp., Santa Clara, CA, USA, 2019, pp. 1291–1307.

[8] T. Koide, N. Fukushi, H. Nakano, and D. Chiba, "ChatSpamDetector: Leveraging large language models for effective phishing email detection," arXiv:2402.18093, 2024.

[9] Z. Guo, M. Schlichtkrull, and A. Vlachos, "A survey on automated fact-checking," *Trans. Assoc. Comput. Linguistics*, vol. 10, pp. 178–206, 2022.

[10] B. Karki, F. Abri, A. Siami Namin, and K. S. Jones, "Using transformers for identification of persuasion principles in phishing emails," in *Proc. IEEE Int. Conf. Big Data*, Osaka, Japan, 2022, pp. 2841–2848.

[11] P. Tooher and H. S. Lallie, "A two-stage deep learning framework for AI-driven phishing email detection based on persuasion principles," *Computers*, vol. 14, no. 12, Art. no. 523, 2025.

[12] T. Pan, Q. Yang, A. J. Cole, R. Wilson, and D. Woodard, "Psychology of phishing emails: Quantifying persuasion principles and simulating detection with large language models," SSRN preprint 5436577, 2025.

[13] H. Gascon, S. Ullrich, B. Stritter, and K. Rieck, "Reading between the lines: Content-agnostic detection of spear-phishing emails," in *Research in Attacks, Intrusions, and Defenses (RAID)* (Lecture Notes in Computer Science, vol. 11050). Cham, Switzerland: Springer, 2018, pp. 69–91.

[14] M. Paul, G. Bartlett, J. Mirkovic, and M. Freedman, "Phishing email detection using inputs from artificial intelligence," arXiv:2405.12494, 2024.

[15] L. Ai et al., "Defending against social engineering attacks in the age of LLMs," in *Proc. Conf. Empirical Methods Natural Lang. Process. (EMNLP)*, Miami, FL, USA, 2024, pp. 12880–12902.

[16] M. Kucherawy, "Message header field for indicating message authentication status," RFC 8601, May 2019, doi: 10.17487/RFC8601.

[17] A. Ferreira, L. Coventry, and G. Lenzini, "Principles of persuasion in social engineering and their use in phishing," in *Human Aspects of Information Security, Privacy, and Trust* (Lecture Notes in Computer Science, vol. 9190), T. Tryfonas and I. Askoxylakis, Eds. Cham, Switzerland: Springer, 2015, pp. 36–47.

[18] F. Stajano and P. Wilson, "Understanding scam victims: Seven principles for systems security," *Commun. ACM*, vol. 54, no. 3, pp. 70–75, 2011.

[19] V. Sanh, L. Debut, J. Chaumond, and T. Wolf, "DistilBERT, a distilled version of BERT: Smaller, faster, cheaper and lighter," arXiv:1910.01108, 2019.

[20] D. Arp et al., "Dos and don'ts of machine learning in computer security," in *Proc. 31st USENIX Security Symp.*, Boston, MA, USA, 2022, pp. 3971–3988.

[21] J. Nazario, "Phishing corpus." Accessed: Oct. 12, 2026. [Online]. Available: https://monkey.org/~jose/phishing/

[22] rf-peixoto, "phishing_pot: A collection of real phishing samples collected via honey pots," GitHub repository. Accessed: Oct. 12, 2026. [Online]. Available: https://github.com/rf-peixoto/phishing_pot

[23] B. Klimt and Y. Yang, "The Enron corpus: A new dataset for email classification research," in *Machine Learning: ECML 2004*. Berlin, Germany: Springer, 2004, pp. 217–226.

[24] A. Al-Subaiey, M. Al-Thani, N. A. Alam, K. F. Antora, A. Khandakar, and S. M. A. U. Zaman, "Novel interpretable and robust web-based AI platform for phishing email detection," *Comput. Electr. Eng.*, vol. 120, Art. no. 109625, 2024.

[25] Apache SpamAssassin Project, "SpamAssassin public corpus." Accessed: Oct. 12, 2026. [Online]. Available: https://spamassassin.apache.org/old/publiccorpus/

[26] Apache Software Foundation, "users@kafka.apache.org and users@tomcat.apache.org mailing-list archives." Accessed: Oct. 12, 2026. [Online]. Available: https://lists.apache.org/

[27] N. Pangakis, S. Wolken, and N. Fasching, "Automated annotation with generative AI requires validation," arXiv:2306.00176, 2023.

[28] R. Geirhos et al., "Shortcut learning in deep neural networks," *Nature Mach. Intell.*, vol. 2, no. 11, pp. 665–673, 2020.